

Cybereason GSOC セキュリティ・アップデート 2025年3月版

偽のCAPTCHAや正規ツールを悪用する
情報窃取型マルウェアLummaStealer

サイバーリーズン合同会社



Defend the Future | ©2025 Cybereason G.K. | All rights reserved

重要なポイント

この資料は「情報窃取型マルウェア、LummaStealerの台頭【Cybereason GSOC セキュリティ・アップデート 2025年1月版】」の続編です

LummaStealerの概要

- Malware-as-a-Service (MaaS) として拡散されている高度なマルウェア
- 2022年に初めて観測され、ロシア語を話す攻撃者によって開発
- 幅広い種類のWindowsシステムを標的とし、検知を回避するために高度な技術を使用

LummaStealerの脅威

- 仮想通貨ウォレット、ユーザー認証情報、二段階認証のブラウザ拡張機能などの機密情報を窃取
- 若い世代のユーザー、成人、企業など標的を選ばない
- 様々な手段で拡散する

観測したLummaStealerに関連付けられる 6つ初期ペイロード

- 脆弱なソフトウェアやクラックされたソフトウェアを使用するDLLサイドローディング
- AutoITスクリプトを含んでいるMSIファイル
- PythonベースのDLL（Pythonwのsetup.exeとDLL）
- LummaStealerペイロードを含んでいる脆弱なソフトウェアやクラックされたソフトウェア
- 実行ファイルとRARを含んでいるMSIファイル
- おとりのPDFファイルを含んでいるZIPファイル

上記に加え、Cybereason GSOCチームは新たなペイロードを観測しました。

LummaStealerの新たな初期ペイロード: MSHTAプロセスの悪用 配布方法

- マルウェアの配布方法としてフィッシングメール経由を観測
- ユーザーを偽のCAPTCHAに誘導する悪意あるリンクが含まれている
- リンクをクリックすると、ユーザーがこのような偽のCAPTCHAページが表示され、第1段階のペイロードを実行するためのプログラムがバックグラウンドで実行される

Date	Name
Jan 7, 2025, 2:02 PM GMT+2	
Jan 7, 2025, 2:02 PM GMT+2	
Jan 7, 2025, 2:02 PM GMT+2	
Jan 7, 2025, 2:02 PM GMT+2	
Jan 7, 2025, 2:02 PM GMT+2	explorer.exe

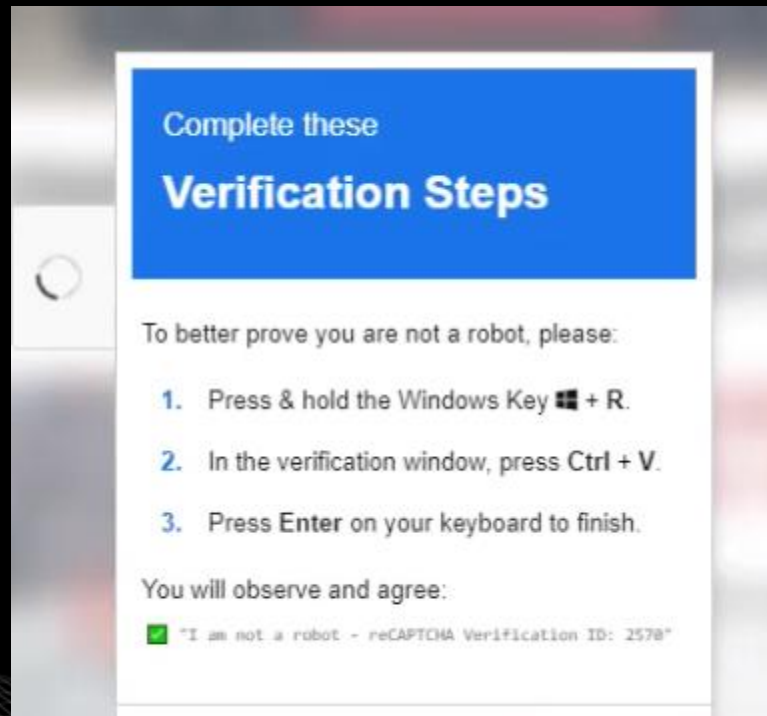
explorer.exe c:\users\user\appdata\roaming\microsoft\windows\recent\microsoft-edge---url=https%3a%2f%2fmaciteration.github.io%2fcoffeebara-v0uch3rz&source=outlook&treatment=...

explorer.exe c:\users\user\appdata\roaming\microsoft\windows\recent\microsoft-edge---url=https%3a%2f%2fmaciteration.github.io%2fcoffeebara-v0uch3rz&source=outlook&treatment=...

Cybereason EDRでフィッシング攻撃を可視化

LummaStealerの新たな初期ペイロード: MSHTAプロセスの悪用 初期アクセス

- 偽のCAPTCHAページには、悪意あるスクリプトをコピーした後、それをWindowsの「ファイル名を指定して実行」ダイアログボックスに貼り付けるようユーザーに要求する仕掛けが含まれている
- 「ファイル名を指定して実行」ダイアログボックスは、ユーザーがサービスを素早く起動して、コマンドを実行できるようにするWindows標準のユーティリティ



偽のCAPTCHA

LummaStealerの新たな初期ペイロード: MSHTAプロセスの悪用 「ファイル名を指定して実行」後のフロー

- mshta.exe経由で配布されたペイロードが、mp4ファイルを装ったファイルをダウンロード
- このマルウェアはペイロードを隠すためにさまざまな難読化手法を使って、検知や分析を困難にしている
- 難読化の手法にはペイロードのHEXエンコード、複雑なJavaScript構造の利用、暗号化、複雑な名前の使用、変数や関数の冗長化などが含まれる
- 悪意あるコードをメモリに直接ロードするという追加のステップを実行
- これにより、従来のファイルベースのセキュリティチェックを回避し、一部のセキュリティシステムにより検知されないままの状態での攻撃を続けることが可能になる



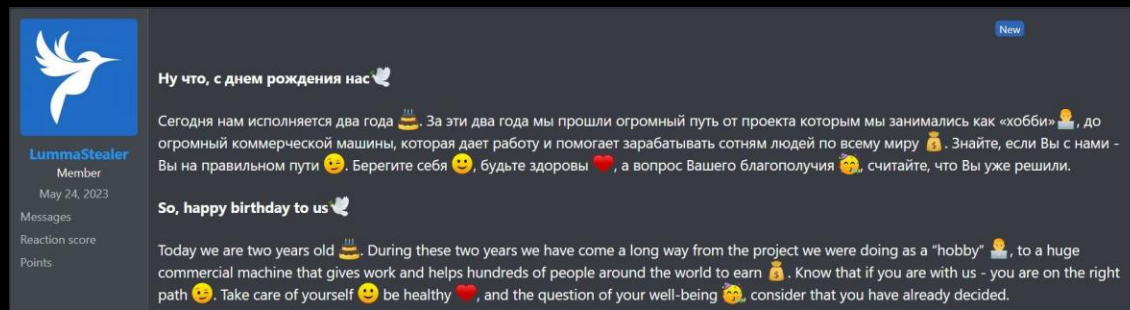
Cybereason EDRで、mshta.exeを悪用し、powershellを実行するところを可視化

LummaStealerによるダークネット上での活動 1/2

- LummaStealerオペレーターは、盗んだデータの直接取引を可能にするテレグラム上のマーケットプレイスを運営
- レーティングシステム、高度な検索機能、柔軟な価格設定を完備

LummaStealerの活動と進化

- 2年前から市場で活動し、記念イベントで新機能を紹介
- 2024年に入り、フィッシングメールや悪意あるダウンロードによる攻撃が増加
- 製造業など、特定の業界を標的とした攻撃も確認されている



LummaStealerのサイト

LummaStealerによるダークネット上での活動 2/2

提供形態

- 経験者、プロフェッショナル、企業向けの3つのサブスクリプション階層を提供
- 各階層で異なる機能、カスタマイズオプション、ツールを提供

マーケットプレイスの特徴

- 自動ボットによるログの売買と取引の簡素化
- 詳細なロット情報、高度な検索・フィルタリング機能、売り手レーティングシステム
- 柔軟な価格設定と暗号通貨による支払いシステム
- GitBookによる詳細なドキュメントとサポート体制

LummaStealerの市場での影響

- テレグラムの利用と高度な機能により、他のインフォスティーラーよりも人気が高い
- 違法マーケットプレイスの専門化を促進し、合法・違法な境界線を曖昧にしている



Lummaマーケットのロゴ

推奨事項1/2

LummaStealerのような脅威に直面した場合には、早急に封じ込め根絶するためには、次のような戦略的措置を実施することを推奨します。

- **感染した端末を隔離する**：感染したデバイスを即座にネットワークから切り離すことで、伝播やラテラルムーブメントを防ぎ、データの流出を防止します
- **アクティブなユーザーセッションをロックする**：影響を受けるユーザーのアクティブなセッションをすべて閉じることで、攻撃者の持つアクセス権を制限します
- **端末上のすべてのユーザーアカウントをブロックする**：mimikatzのようなクレデンシャルダンプスクリプトが確認されているため、不正アクセスを制限するには、ハッキングされたエンドポイント上に存在するすべてのユーザーアカウントを無効にすることが極めて重要です
- **感染した端末を再イメージ化する**：デバイスを再イメージしてシステムを復元することで、悪意あるアーティファクトを完全に削除します

推奨事項 2/2

- **ユーザーの認証情報をリセットする**：ハッキングされた端末に関連するすべての認証情報がリセットされていることを確認すること。これには、アカウント、ブラウザに保存されたパスワード、暗号ウォレット、およびデバイスに保存された機密関連情報などが含まれます。さらに、可能であれば2FAを適用します。
- **IOCをブロックする**：インシデント発生時に観測されたドメイン/IPアドレスを、組織のファイアウォール/プロキシ/メールゲートウェイから確実にブロックします。
- **ユーザーを教育する**：通常、初期アクセスは人との対話なしには実施されません。ユーザーが自力で信頼できないサイトの不審なCAPTCHAプロンプトを特定して回避できるようにするためや、フィッシングメールを自力で検知できるようにするために、ユーザー教育を実施します。

Cybereason EDRでは、難読化されたコマンドラインや正規プロセスが示す異常な動作を検知し、可視化する機能を備えています。



サイバーリーズン合同会社
www.cybereason.co.jp